PHISHING EMAIL DETECTION & AWARENESS SYSTEM

Name: Harshitha Vardhini Mademu

Date: 17th Apr, 2026

INTRODCTION:

This report presents a detailed vulnerability assessment of suspicious emails received in a controlled environment. The objective is to identify phishing characteristics, analyze email headers, and evaluate potential security risks.

Phishing emails are a major cybersecurity threat where attackers impersonate legitimate organizations to trick users into revealing sensitive information or clicking malicious links.

In this report, three different emails are analyzed:

- Promotional phishing email (Email 1 & 2)
- Account security alert phishing email (Email 3)

The analysis includes:

- Header inspection
- Sender verification
- Link analysis
- Social engineering techniques

OBJECTIVE:

The main objectives of this vulnerability assessment are:

- To identify phishing indicators in real-world emails
- To analyze email headers for authenticity verification
- To detect spoofed domains and misleading sender identities
- To evaluate malicious links embedded in emails
- To understand social engineering tactics used by attackers
- To document findings in a structured cybersecurity report

This task helps build practical skills in:

- Email forensic analysis
- Threat detection
- Security awareness

It also simulates real-world scenarios where organizations must assess whether emails are safe or malicious.

TOOLS USED:

- Kali Linux
- Google Message Header Analyzer
- MXToolbox
- Whois
- Dig

METHODOLOGY:

The analysis was performed using a structured approach similar to real-world Security Operations Center (SOC) workflows.

Step 1: Collection of Email Samples

Phishing email samples were collected from publicly available repositories on GitHub in .eml format, containing full email headers and body content.

Step 2: Email Header Extraction

The emails were opened in Kali Linux and important header fields such as From, Return-Path, Received and Message-ID were extracted.

Step 3: Header Analysis

The headers were analyzed using Google Message Header Analyzer and MXToolbox to verify SPF, DKIM and DMARC authentication.

Step 4: Link and Domain Analysis

Suspicious links were identified and checked using WHOIS and dig to verify domain legitimacy.

Step 5: Content Analysis

The email subject and body were examined for phishing indicators such as urgency, offers, and impersonation.

Step 6: Risk Classification

Each email was classified as Safe, Suspicious or Phishing based on the findings.

Step 7: Safety Measures

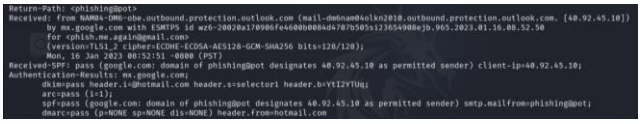
All analysis was conducted in a read-only environment without interacting with malicious content.

EMAIL 1 ANALYSIS:

Overview:

This email promotes a discount on antivirus software (Total Protection), which is a common phishing strategy used to lure users into clicking malicious links.

```
From: phishing@pot <phishing@pot>
To: "phish.me.again@gmail.com" <phish.me.again@gmail.com>
Subject: ENC: Save up to 67% on Total Protection
Thread-Topic: Save up to 67% on Total Protection
Thread-Index: AQHZKOVLt3+Lo1cJ7Uej0S9rmXuOBa6hRB2m
Date: Mon, 16 Jan 2023 16:52:49 +0000
Message-ID:
 <SA0PR04MB7370S2C745482CA645A04D01B3C19@SA0PR04MB7370.namprd04.prod.outlook.com>
References:
 <bac6cf83-1014-4f50-9df5-8bc0f5124dc7@HE1EUR04FT051.eop-eur04.prod.protection.outlook.com>
```



```
Return-Path: <phishing@pot>
Received: from NAM04-DM6-obe.outbound.protection.outlook.com (mail-dm6nam04olkn2010.outbound.protection.outlook.com. [40.92.45.10])
        by mx.google.com with ESMTPS id wz6-20020a170906f64600b0084d4707b505s12365490 8ejb.965.2023.01.16.08.52.50
        for <phish.me.again@gmail.com>
        (version=TLS1_2 cipher=ECDHE-ECDSA-AES128-GCM-SHA256 bits=128/128);
        Mon, 16 Jan 2023 08:52:51 -0800 (PST)
Received-SPF: pass (google.com: domain of phishing@pot designates 40.92.45.10 as permitted sender) client-ip=40.92.45.10;
Authentication-Results: mx.google.com;
        dkim=pass header.i=@hotmail.com header.s=selector1 header.b=YtI2YTUq;
        arc=pass (i=1);
        spf=pass (google.com: domain of phishing@pot designates 40.92.45.10 as permitted sender) smtp.mailfrom=phishing@pot;
        dmarc=pass (p=NONE sp=NONE dis=NONE) header.from=hotmail.com
```

Header Analysis:

- Sender: phishing@pot (suspicious and non-legitimate domain)
- Return-Path: Matches sender domain
- SPF: Pass
- DKIM: Pass
- DMARC: Weak/None
- Multiple “Received” headers indicate routing through Microsoft servers

Analysis Using Tools:

The email header was analyzed using:

- Google Message Header Analyzer
- MXToolbox

These tools confirmed that authentication checks passed, but the sender domain is not trustworthy.

Body & Link Analysis:

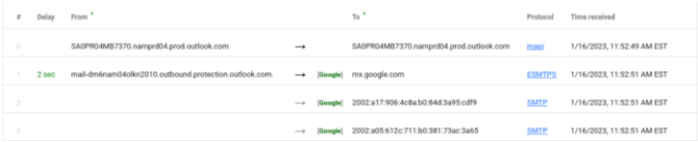
- Contains promotional language (“Save up to 67%”)
- Includes suspicious tracking URL (hannu.site)
- Uses marketing-style phishing technique
- Contains unsubscribe link to appear legitimate

Findings:

- Fake sender domain
- Malicious external link
- Social engineering (discount lure)
- Authentication bypass (SPF/DKIM pass)

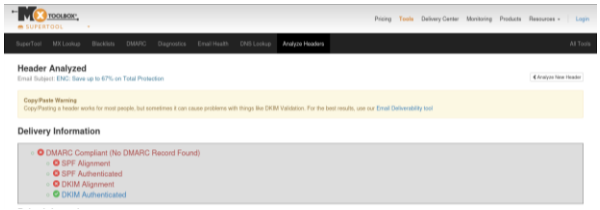
GOOGLE ADMIN TOOL BOX:

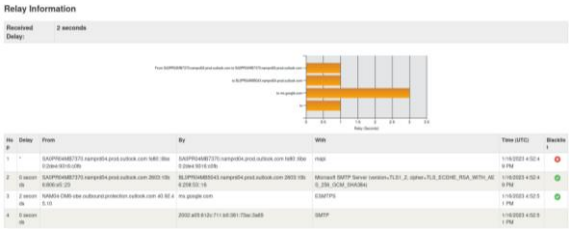
Messageid	SA0PR04MB737052C745482CA645A04D01B3C19@SA0PR04MB7370.namprd04.prod.outlook.com
Created at:	1/16/2023, 11:52:49 AM EST (Delivered after 2 sec)
From:	phishing@pot <phishing@pot>
To:	"phish.me.again@gmail.com" <phish.me.again@gmail.com>
Subject:	ENC: Save up to 67% on Total Protection
SPF:	pass with IP 40.92.45.10 Learn more
DKIM:	pass with domain hotmail.com Learn more
ARC:	pass
DMARC:	pass Learn more



#	Delay	From *			To *	Protocol	Time received
0		SA0PR04MB7370.namprd04.prod.outlook.com	→		SA0PR04MB7370.namprd04.prod.outlook.com	mapi	1/16/2023, 11:52:49 AM EST
1	2 sec	mail-dm6nam04olkn2010.outbound.protection.outlook.com.	→	[Google]	mx.google.com	ESMTPS	1/16/2023, 11:52:51 AM EST
2			→	[Google]	2002:a17:906:4c8a:b0:84d:3a95:cdf9	SMTP	1/16/2023, 11:52:51 AM EST
3			→	[Google]	2002:a05:612c:711:b0:381:73ac:3a65	SMTP	1/16/2023, 11:52:51 AM EST

MX TOOLBOX:





Conclusion:

This email is classified as **Phishing** due to fake sender identity and malicious link.

EMAIL 2 ANALYSIS:

Overview:

This email is part of a repeated phishing campaign promoting antivirus software discounts. It follows a similar structure to Email Sample 1, indicating automated bulk distribution.

```
From: phishing@pot <phishing@pot>
To: "phish.me.again@gmail.com" <phish.me.again@gmail.com>
Subject: EWC: Save up to 67% on Total Protection
Thread-Topic: Save up to 67% on Total Protection
Thread-Index: AQHZKZSqthSHT+HPi0SGsrJ+1FbwJ66hQouq
Date: Mon, 16 Jan 2023 16:52:20 +0000
Message-ID:
 <5A0PR04MB7370B0F9BEEF6D0CA5E6E6B9B3C19@5A0PR04MB7370.namprd04.prod.outlook.com>
References:
 <d551c943-0667-488b-9215-75e039af404e@MW2NAM10FT062.eop-nam10.prod.protection.outlook.com>
```

```
Return-Path: <phishing@pot>
Received: from NAM11-DM6-obe.outbound.protection.outlook.com (mail-dm6nam11olkn2052.outbound.protection.outlook.com. [40.92.19.52])
        by mx.google.com with ESMTPS id cs10-20020a056402c4a00b00499cf6bd2fasi19116849edb.66.2023.01.16.08.52.24
        for <phish.me.again@gmail.com>
        (version=TLS1_2 cipher=ECDHE-ECDSA-AES128-GCM-SHA256 bits=128/128);
        Mon, 16 Jan 2023 08:52:24 -0800 (PST)
Received-SPF: pass (google.com: domain of phishing@pot designates 40.92.19.52 as permitted sender) client-ip=40.92.19.52;
Authentication-Results: mx.google.com;
        dkim=pass header.i=@hotmail.com header.s=selector1 header.b=gEmy6wr8;
        arc=pass (i=1);
        spf=pass (google.com: domain of phishing@pot designates 40.92.19.52 as permitted sender) smtp.mailfrom=phishing@pot;
        dmarc=pass (p=NONE sp=NONE dis=NONE) header.from=hotmail.com
```

Header Analysis:

- Sender address: phishing@pot (not a legitimate domain)
- SPF: Pass
- DKIM: Pass
- DMARC: Weak/None
- Multiple “Received” headers show routing through Microsoft servers

Analysis Using Tools:

The header was analyzed using:

- Google Message Header Analyzer
- MXToolbox

Both tools confirmed that although authentication checks passed, the domain itself is suspicious.

Body & Link Analysis:

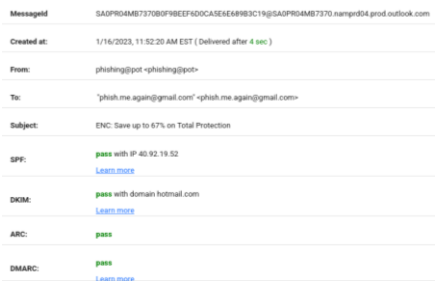
- The email content is nearly identical to Email Sample 1, indicating reuse of a phishing template.
- It promotes a discount offer (“Save up to 67%”), which is a common **social engineering tactic**.
- Contains a suspicious tracking link pointing to an external domain (hannu.site).
- The link is **not related to any legitimate antivirus provider**, indicating phishing intent.

- The email includes an unsubscribe option to appear trustworthy.
- Language and structure suggest automated bulk email distribution.

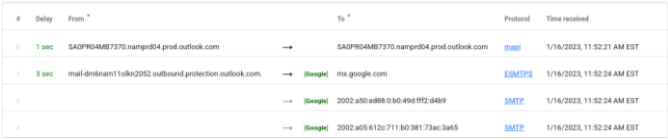
Findings:

- Reused phishing template
- Different sending IP (evasion technique)
- Same malicious link pattern
- Indicates coordinated phishing campaign

GOOGLE ADMIN TOOL BOX:

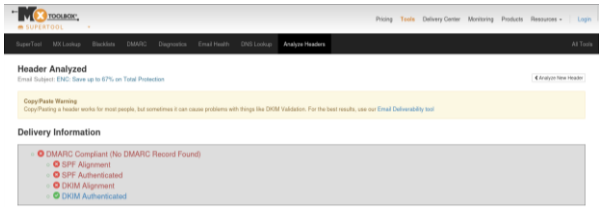


Messageid	SA0PR04MB7370B0F9BEEF6D0CA5E5E6899B3C19@SA0PR04MB7370.namprd04.prod.outlook.com
Created at:	1/16/2023, 11:52:20 AM EST (Delivered after 4 sec)
From:	phishing@pot <phishing@pot>
To:	"phish.me.again@gmail.com" <phish.me.again@gmail.com>
Subject:	ENC: Save up to 67% on Total Protection
SPF:	pass with IP 40.92.19.52 Learn more
DKIM:	pass with domain hotmail.com Learn more
ARC:	pass
DMARC:	pass Learn more



#	Delay	From *		To *	Protocol	Time received
0	1 sec	SA0PR04MB7370.namprd04.prod.outlook.com	→	SA0PR04MB7370.namprd04.prod.outlook.com	mapi	1/16/2023, 11:52:21 AM EST
1	3 sec	mail-dm6nam11olkn2052.outbound.protection.outlook.com.	→	|Google| mx.google.com	ESMTPS	1/16/2023, 11:52:24 AM EST
2			→	|Google| 2002:a50:ed88:0:b0:49d:fff2:d4b9	SMTP	1/16/2023, 11:52:24 AM EST
3			→	|Google| 2002:a05:612c:711:b0:381:73ac:3a65	SMTP	1/16/2023, 11:52:24 AM EST

MX TOOLBOX:



Conclusion:

The presence of a malicious external link combined with promotional bait confirms this email as a phishing attempt.

EMAIL 3 ANALYSIS:

Overview:

This email impersonates a Microsoft security alert, claiming unusual sign-in activity. This is a high-risk phishing tactic designed to create urgency and panic.

```
From: phishing@pot <phishing@pot>
To: "phish.me.again@gmail.com" <phish.me.again@gmail.com>
Subject: ENC: Microsoft account unusual sign-in activity
Thread-Topic: Microsoft account unusual sign-in activity
Thread-Index: AQHZKQNDDC6/5kt1jkub3gxO5ytsKq6hQ9CG
Date: Mon, 16 Jan 2023 16:52:33 +0000
Message-ID:
 <5A0PR04MB7370E5053E3A37C4B316FCB5B3C19@5A0PR04MB7370.namprd04.prod.outlook.com>
References:
 <6893279e-ad27-4d43-b55b-cb1463e707c3@DM6NAM12FT020.eop-nam12.prod.protection.outlook.com>
```

```
Return-Path: <phishing@pot>
Received: from NAM04-DM6-obe.outbound.protection.outlook.com (mail-dm6nam04olkn2068.outbound.protection.outlook.com. [40.92.45.68])
        by mx.google.com with ESMTPS id hg23-20020a170907e170b0080070e0c1f5066i352216e1c.370.2023.01.16.08.52.35
        for <phish.me.again@gmail.com>
        (version=TLS1_2 cipher=ECDHE-ECDSA-AES128-GCM-SHA256 bits=128/128);
        Mon, 16 Jan 2023 08:52:35 -0800 (PST)
Received-SPF: pass (google.com: domain of phishing@pot designates 40.92.45.68 as permitted sender) client-ip=40.92.45.68;
Authentication-Results: mx.google.com;
        dkim=pass header.i=@hotmail.com header.s=selector1 header.b="m/f5ffgE";
        arc=pass (i=1);
        spf=pass (google.com: domain of phishing@pot designates 40.92.45.68 as permitted sender) smtp.mailfrom=phishing@pot;
        dmarc=pass (p=NONE sp=NONE dis=NONE) header.from=hotmail.com
```

Header Analysis:

- Subject indicates security alert
- Sender: phishing@pot (not Microsoft)
- SPF & DKIM: Pass (misleading trust signal)
- DMARC: Weak/None

Analysis Using Tools:

The email header was analyzed using:

- Google Message Header Analyzer
- MXToolbox

The tools confirmed that authentication passed, but no strong domain protection policy exists.

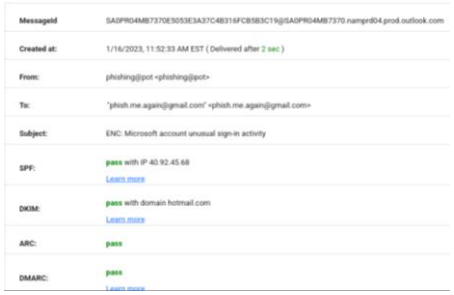
Body & Link Analysis:

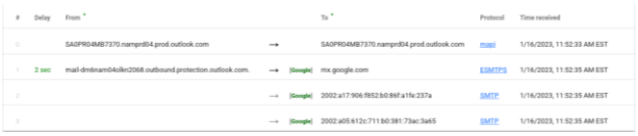
- The email claims **"Microsoft account unusual sign-in activity"**, creating urgency and fear.
- This is a classic **credential harvesting phishing technique**.
- Although the body content is minimal in the sample, such emails typically contain:
    - A login verification link
    - A "secure your account" button
- The sender domain (phishing@pot) does not match Microsoft, indicating impersonation.
- Likely redirects users to a fake login page.

Findings:

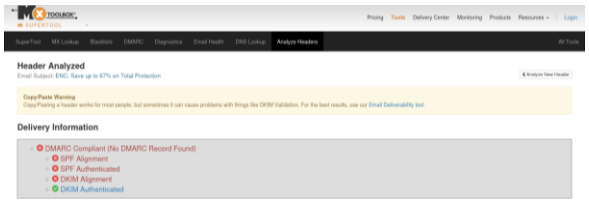
- Clear impersonation attack
- Mismatch between sender and claimed organization
- Likely contains credential harvesting link
- Uses urgency-based language

GOOGLE ADMIN TOOL BOX:





MXTOOLBOX:



Conclusion:

Even without a visible link, the impersonation and urgency strongly indicate a phishing attack.

INDICATORS OF COMPROMISE (IOS):

The following indicators were identified:

- Suspicious sender: phishing@pot
- Malicious domain: hannu.site
- Repeated subject lines
- Multiple IP addresses used
- SPF/DKIM pass despite malicious intent
- Use of impersonation (Microsoft alert)
- Embedded tracking links

RISK CLASSIFICATION:

Email Sample	**Risk Level**	**Reason**
Email 1	Phishing	Fake domain + malicious link
Email 2	Phishing	Campaign pattern + spoofing
Email 3	Phishing	Microsoft impersonation

All emails were classified as **Phishing** due to strong malicious indicators.

HOW THE PHISHING ATTACK WORKS:

Phishing attacks follow a simple process:

1. The attacker sends a fake email impersonating a trusted organization
2. The email creates urgency or offers to attract the user
3. The user clicks on the malicious link
4. The link redirects to a fake website
5. The user enters sensitive information
6. The attacker steals the data for misuse

DO’S AND DON’TS FOR EMPLOYEES:

Do’s:

- Verify sender email address before responding
- Hover over links before clicking
- Report suspicious emails to IT team
- Use strong passwords and security tools

Don’ts:

- Do not click unknown links
- Do not download attachments from unknown senders
- Do not share personal or login details via email
- Do not trust urgent or threatening messages blindly

CONCLUSION:

The analysis demonstrates that phishing emails can successfully pass authentication checks like SPF and DKIM while still being malicious.

Attackers used:

- Social engineering techniques
- Domain spoofing
- Repeated campaign structures

This highlights the importance of analyzing email headers and not relying solely on authentication results.

RECOMMENDATIONS:

- Verify sender domains carefully
- Avoid clicking unknown links
- Use advanced email filtering tools
- Implement strict DMARC policies
- Conduct cybersecurity awareness training
- Monitor suspicious domains regularly